CONTRAT DE TRAITEMENT DE DONNÉES PERSONNELLES (ACCORD DE SOUS-TRAITANCE – ARTICLE 28 DU RGPD)

> *Modèle gratuit Lumen Juris, à adapter à votre situation. Les passages entre crochets [ ] sont à compléter ou à choisir. Les notes de rédaction (comme celle-ci) sont à supprimer avant signature.*

> *Note de rédaction : ce contrat s'ajoute au contrat commercial (prestation, abonnement SaaS, hébergement, paie externalisée, centre d'appels…) lorsque le prestataire traite des données personnelles pour le compte de son client. Il ne convient pas si le prestataire utilise les données pour ses propres finalités : il est alors lui-même responsable de traitement, et un autre type d'accord est nécessaire.*

ENTRE LES SOUSSIGNÉS :

La société [dénomination], [forme sociale] au capital de [montant] €, dont le siège social est situé [adresse], immatriculée au RCS de [ville] sous le numéro [numéro SIREN], représentée par [prénom et nom], en qualité de [fonction], dûment habilité(e),

Ci-après dénommée « le Responsable de traitement »,

D'UNE PART,

ET :

La société [dénomination], [forme sociale] au capital de [montant] €, dont le siège social est situé [adresse], immatriculée au RCS de [ville] sous le numéro [numéro SIREN], représentée par [prénom et nom], en qualité de [fonction], dûment habilité(e),

Ci-après dénommée « le Sous-traitant »,

D'AUTRE PART,

Le Responsable de traitement et le Sous-traitant étant ensemble dénommés « les Parties ».

IL A ÉTÉ PRÉALABLEMENT EXPOSÉ CE QUI SUIT :

Les Parties ont conclu le [date] un contrat de [nature de la prestation] (ci-après « le Contrat principal »). Pour l'exécuter, le Sous-traitant traite des données à caractère personnel pour le compte du Responsable de traitement. Le présent contrat fixe les conditions de ce traitement, conformément à l'article 28 du règlement (UE) 2016/679 du 27 avril 2016 (ci-après « le RGPD ») et à la loi n° 78-17 du 6 janvier 1978 modifiée.

CECI EXPOSÉ, IL A ÉTÉ CONVENU CE QUI SUIT :

ARTICLE 1 – DÉFINITIONS

Les termes « données à caractère personnel », « traitement », « responsable du traitement », « sous-traitant », « violation de données à caractère personnel » et « personne concernée » ont le sens que leur donne l'article 4 du RGPD.

ARTICLE 2 – OBJET ET DESCRIPTION DU TRAITEMENT

Le Sous-traitant est autorisé à traiter, pour le compte du Responsable de traitement, les données nécessaires à la fourniture du service suivant : [description du service].

Les caractéristiques du traitement sont décrites en annexe 1 :

- nature des opérations : [collecte / hébergement / consultation / modification / envoi / suppression / autre] ;
- finalité : [gestion de la paie / hébergement du site / envoi de newsletters / support client / autre] ;
- catégories de données : [identité, coordonnées, données de connexion, données bancaires, autres] ;
- catégories de personnes concernées : [clients / prospects / salariés / candidats / patients / autres] ;
- durée du traitement : celle du Contrat principal, puis la durée nécessaire à la restitution ou à la suppression prévue à l'article 11.

> *Note de rédaction : si le traitement porte sur des données sensibles (santé, opinions, données biométriques, infractions) ou sur des mineurs, signalez-le dans l'annexe 1 et renforcez les mesures de sécurité de l'annexe 2. Pour des données de santé, l'hébergeur doit en principe être certifié HDS.*

ARTICLE 3 – INSTRUCTIONS DU RESPONSABLE DE TRAITEMENT

Le Sous-traitant traite les données uniquement sur instruction documentée du Responsable de traitement. Le présent contrat, ses annexes et le Contrat principal constituent les instructions initiales. Toute instruction complémentaire est donnée par écrit, y compris par courriel à l'adresse [adresse].

Cette règle s'applique aussi aux transferts de données vers un pays situé hors de l'Union européenne, sauf si le droit de l'Union ou d'un État membre impose au Sous-traitant de les traiter ; il en informe alors le Responsable de traitement avant le traitement, sauf si ce droit l'interdit.

Si le Sous-traitant considère qu'une instruction constitue une violation du RGPD ou d'une autre règle de protection des données, il en informe immédiatement le Responsable de traitement. Il peut suspendre l'exécution de cette instruction jusqu'à ce qu'elle soit confirmée ou modifiée par écrit.

Le Sous-traitant n'utilise pas les données pour ses propres finalités, notamment commerciales, statistiques ou d'entraînement de systèmes d'intelligence artificielle, sauf accord écrit préalable du Responsable de traitement.

ARTICLE 4 – CONFIDENTIALITÉ

Le Sous-traitant veille à ce que les personnes autorisées à traiter les données, salariés comme prestataires, s'engagent à en respecter la confidentialité ou soient soumises à une obligation légale de confidentialité. Il limite l'accès aux seules personnes qui en ont besoin pour exécuter le service, et les forme à la protection des données.

ARTICLE 5 – SÉCURITÉ DES DONNÉES

Le Sous-traitant met en œuvre les mesures techniques et organisationnelles appropriées pour garantir un niveau de sécurité adapté au risque, comme l'exige l'article 32 du RGPD. Ces mesures, décrites en annexe 2, comprennent au minimum :

- le contrôle et la journalisation des accès ;
- le chiffrement des données [en transit / au repos] ;
- des sauvegardes régulières et testées ;
- une procédure de gestion des incidents ;
- la mise à jour des systèmes et logiciels.

Le Sous-traitant ne peut diminuer le niveau de sécurité décrit en annexe 2 pendant la durée du contrat. Il informe le Responsable de traitement de toute modification importante de ces mesures.

ARTICLE 6 – SOUS-TRAITANCE ULTÉRIEURE

6.1 Autorisation

Le Sous-traitant peut faire appel aux sous-traitants ultérieurs listés en annexe 3, que le Responsable de traitement autorise par la signature du présent contrat.

[Option 1 – autorisation générale] Pour tout ajout ou remplacement, le Sous-traitant informe le Responsable de traitement par écrit au moins [trente] jours à l'avance, en indiquant l'identité du sous-traitant ultérieur, les traitements confiés et le lieu du traitement. Le Responsable de traitement peut s'y opposer pendant ce délai par écrit et de manière motivée. En cas d'objection, les Parties recherchent une solution ; à défaut, le Responsable de traitement peut résilier sans pénalité la partie du Contrat principal concernée.

[Option 2 – autorisation spécifique] Tout nouveau sous-traitant ultérieur nécessite l'autorisation écrite préalable du Responsable de traitement.

6.2 Obligations transmises

Le Sous-traitant impose par contrat écrit à chaque sous-traitant ultérieur les mêmes obligations de protection des données que celles du présent contrat, notamment en matière de sécurité. Il reste pleinement responsable envers le Responsable de traitement de l'exécution de ces obligations par le sous-traitant ultérieur.

ARTICLE 7 – TRANSFERTS HORS DE L'UNION EUROPÉENNE

Les données sont traitées et hébergées dans [l'Union européenne / l'Espace économique européen / les pays listés en annexe 3].

Aucun transfert, y compris un simple accès à distance depuis un pays tiers, n'a lieu sans instruction écrite du Responsable de traitement et sans l'une des garanties prévues au chapitre V du RGPD : décision d'adéquation de la Commission européenne, clauses contractuelles types de la Commission, ou règles d'entreprise contraignantes. Le Sous-traitant documente la garantie utilisée et, le cas échéant, l'évaluation des lois du pays de destination et les mesures complémentaires mises en place.

ARTICLE 8 – DROITS DES PERSONNES CONCERNÉES

Le Sous-traitant aide le Responsable de traitement, par des mesures techniques et organisationnelles appropriées, à répondre aux demandes des personnes concernées (accès, rectification, effacement, limitation, portabilité, opposition).

Si une personne concernée adresse directement une demande au Sous-traitant, celui-ci la transmet au Responsable de traitement dans un délai de [cinq] jours ouvrés, sans y répondre lui-même, sauf instruction contraire.

ARTICLE 9 – VIOLATIONS DE DONNÉES

Le Sous-traitant notifie au Responsable de traitement toute violation de données à caractère personnel dans les meilleurs délais après en avoir pris connaissance, et au plus tard dans un délai de [quarante-huit] heures, à l'adresse [adresse de contact]. La notification comprend, dans la mesure du possible :

- la nature de la violation, les catégories et le nombre approximatif de personnes et d'enregistrements concernés ;
- le nom et les coordonnées du point de contact ;
- les conséquences probables de la violation ;
- les mesures prises ou proposées pour y remédier et en limiter les effets.

Si toutes les informations ne sont pas disponibles, elles sont communiquées au fur et à mesure. Le Sous-traitant ne notifie pas lui-même la violation à la CNIL ni aux personnes concernées, sauf instruction écrite du Responsable de traitement.

> *Note de rédaction : le responsable de traitement doit notifier la violation à la CNIL dans les 72 heures après en avoir pris connaissance, lorsqu'elle présente un risque pour les personnes. Un délai de 24 à 48 heures pour le sous-traitant lui laisse le temps d'analyser l'incident.*

ARTICLE 10 – ASSISTANCE ET DOCUMENTATION

Le Sous-traitant aide le Responsable de traitement, compte tenu de la nature du traitement et des informations dont il dispose, à respecter ses obligations relatives à la sécurité, aux violations de données, aux analyses d'impact et à la consultation préalable de la CNIL.

Le Sous-traitant tient un registre des catégories d'activités de traitement effectuées pour le compte du Responsable de traitement. Il a désigné un délégué à la protection des données : [nom et coordonnées / non désigné, la désignation n'étant pas obligatoire pour le Sous-traitant].

ARTICLE 11 – SORT DES DONNÉES EN FIN DE CONTRAT

Au terme du Contrat principal, le Sous-traitant, au choix du Responsable de traitement exprimé par écrit dans un délai de [trente] jours :

- restitue l'ensemble des données dans un format [structuré, couramment utilisé et lisible par machine : CSV, JSON, autre] ;
- ou les supprime, ainsi que toutes les copies existantes, y compris chez ses sous-traitants ultérieurs.

À défaut de choix dans ce délai, les données sont [restituées puis supprimées / supprimées]. La suppression des sauvegardes intervient au plus tard [quatre-vingt-dix] jours après la fin du contrat. Le Sous-traitant justifie par écrit de la suppression. Il ne conserve que les données dont la loi lui impose la conservation, pour la durée et les finalités prévues par cette loi.

ARTICLE 12 – AUDITS

Le Sous-traitant met à la disposition du Responsable de traitement toutes les informations nécessaires pour démontrer le respect du présent contrat, notamment ses certifications et rapports d'audit récents.

Le Responsable de traitement peut faire réaliser un audit, par lui-même ou par un auditeur indépendant tenu au secret et non concurrent du Sous-traitant, [une fois par an] et après un préavis de [trente] jours, sauf violation de données ou demande d'une autorité de contrôle, où le préavis est réduit à [cinq] jours ouvrés. L'audit se déroule pendant les heures ouvrées et sans perturber l'activité du Sous-traitant. Chaque Partie supporte ses propres frais, sauf si l'audit révèle un manquement grave du Sous-traitant, auquel cas il en rembourse le coût raisonnable.

ARTICLE 13 – OBLIGATIONS DU RESPONSABLE DE TRAITEMENT

Le Responsable de traitement s'engage à :

- fournir au Sous-traitant les données et les instructions nécessaires, conformes au RGPD ;
- disposer d'une base légale pour chaque traitement confié et informer les personnes concernées ;
- tenir son propre registre des activités de traitement ;
- superviser le traitement, y compris par des audits.

ARTICLE 14 – RESPONSABILITÉ

Chaque Partie est responsable des dommages causés par un traitement qui ne respecte pas ses propres obligations au titre du RGPD. Le Sous-traitant n'est responsable que s'il n'a pas respecté les obligations qui incombent spécifiquement aux sous-traitants ou s'il a agi en dehors des instructions licites du Responsable de traitement ou contrairement à elles.

> *Option : les plafonds de responsabilité du Contrat principal s'appliquent au présent contrat, sauf pour les violations de données causées par une faute du Sous-traitant, plafonnées à [montant ou multiple du prix annuel]. Vérifiez la cohérence avec l'assurance cyber du Sous-traitant.*

ARTICLE 15 – DURÉE ET ARTICULATION AVEC LE CONTRAT PRINCIPAL

Le présent contrat entre en vigueur à sa signature et prend fin à la date à laquelle le Sous-traitant a restitué ou supprimé toutes les données conformément à l'article 11. En cas de contradiction entre le présent contrat et le Contrat principal sur la protection des données, le présent contrat l'emporte.

ARTICLE 16 – DROIT APPLICABLE ET LITIGES

Le présent contrat est soumis au droit français. Les Parties recherchent une solution amiable pendant [trente] jours à compter de la notification écrite d'un différend. À défaut, le litige est porté devant le tribunal compétent désigné par le Contrat principal.

Fait à [ville], le [date], en deux exemplaires originaux.

Pour le Responsable de traitement : [nom, fonction, signature]

Pour le Sous-traitant : [nom, fonction, signature]

ANNEXE 1 – DESCRIPTION DU TRAITEMENT

[Finalités, nature des opérations, catégories de données (en signalant les données sensibles), catégories de personnes concernées, durée de conservation, lieux de traitement]

ANNEXE 2 – MESURES DE SÉCURITÉ

[Mesures techniques et organisationnelles détaillées : gestion des accès, authentification, chiffrement, sauvegardes, journalisation, sécurité physique, gestion des incidents, certifications]

ANNEXE 3 – SOUS-TRAITANTS ULTÉRIEURS AUTORISÉS

[Pour chacun : dénomination, adresse, service rendu, données concernées, pays de traitement, garantie en cas de transfert hors de l'Union européenne]

Modèle Lumen Juris – https://www.lumenjuris.com/outil-generation-contrat-ia/modele-contrat/contrat-de-traitement-de-donnees-personnelles/